

Vulnerability Audit and Assessment – Baseline Analysis and Plan

Overview

Due to the rapid rise in cybersecurity threats to websites, proactive vulnerability assessments are crucial to ensuring robust website security (Armando et al., 2022). The aim of the proposed vulnerability assessment is to instigate such proactive security processes for PortSwigger's (2023) 'Gin & Juice' JavaScript-based e-commerce website.

A baseline assessment of the website and its potential vulnerabilities

In the context of e-commerce websites, vulnerabilities can lead to insecure handling of sensitive information (Yu et al. 2023). Web users thus run the risk of exposing their financial information, email address, physical address, as well as their behaviour data (Wu et al, 2021). The following table maps the OWASP (2021) top-10 web application security risks to a number of known e-commerce application vulnerabilities, as well as JavaScript-based website vulnerabilities:

<u>Top-10 general web application security vulnerabilities (OWASP, 2021)</u>	<u>E-commerce/ JavaScript website-specific vulnerabilities</u>
Broken Access controls	Prototype pollution can be enacted in JavaScript-based websites which can lead to objects receiving values that they were not permitted to have (Kluban, Mannan & Youssef, 2024).
Cryptographic Failures	Ecommerce applications involve data transmission failure involving faulty digital signatures and encryption for security (Yu et al., 2023) – such encryption may not be secure within the analysed e-commerce website.
Injection	-Formjacking: malicious code injected into a web form to extract then send sensitive data to an attacker (Dharmavaram, 2021); -XML external entity injection attacks from misconfigured CML parsers (Shahid et al., 2022).
Insecure Design	An unsafe regular expression to sanitise input has been found within JSON.parse polyfill by some web domains – this can lead to a ReDoS attack (Kluban, Mannan & Youssef, 2024).
Security Misconfiguration	-In e-commerce websites, merchant systems incorporate various payment methods from TPPs (Yu et al., 2023) – this increases the attack surface and likelihood of security misconfigurations; -Lack of Content Security Policy (CSP) headers on the backend to tell the browser what behaviours are expected from client-side application (Freeman, 2024).
Vulnerable and Outdated Components	-Outdated JavaScript framework versions such as Angular JS can lead to prototype pollution attacks (Kluban, Mannan & Youssef, 2024).

Identification and Authentication Failures	-E-commerce systems rely on distributed and concurrent interactions among web applications involving clients, merchants, and third-party payment platforms (TPPs) for cashier services (Yu et al., 2023) – such processes could involve identification and authentication failures. - Merchants update the order status after the payment is completed (Yu et al., 2023) – this is another possible attack vector.
Software and Data Integrity Failures	- Session management: maintaining session states is crucial for security, where cookies can contain orderID and other sensitive data (Yu et al., 2023). Cookies containing such sensitive data could be compromised cross-site scripting (XSS) (Freeman, 2024). - Data validation: merchants use functions to validate the integrity of the transaction amount (Yu et al., 2023) – these could contain flaws that open up an attack vector.
Security Logging and Monitoring Failures	Ignored login failures, transaction failures, unclear error warnings (Armando & Rosalina, 2023).
Server-Side Request Forgery	Malicious users can potentially alter http control and data flows through concurrent interactions due to logical errors or a lack of server-side validations (Yu et al., 2023; Armando & Rosalina, 2023).

Standards relevant to e-commerce

Pertinent to e-commerce website functionality, GDPR laws state that personal data must be handled in a manner that ensures its security, wherein strong security measures protect data from unauthorised access, breaches, and misuse (GDPR Advisor, 2023). Additionally, CPI DSS standards ensure that security protocols are followed by third parties who deal with payment card transactions (IT Governance, 2025). This vulnerability assessment aims to bring the analysed website in-line with these standards.

Tools and methodology

The vulnerability assessment intends to employ OWASP ZAP and Wapiti3 as the automated vulnerability scanners, as cyber security experts have ranked these as the top 2 non-commercial vulnerability scanning tools (Albahar, Alansari & Jurcut, 2022). However, due to financial restrictions, the current vulnerability assessment is unable to employ the overall highest-rated scanning tool: Burp Suite Professional (Albahar, Alansari & Jurcut, 2022). Additionally, despite being highly rated, it is still possible that the chosen 2 scanning tools will throw up false positives (Landoll, 2021), while false negatives can also be generated if automated scanning is employed on the entire site (Dalziel, 2015). Indeed, manual vulnerability discovery is suggested to be the most accurate method of vulnerability detection (Singh, 2022), and thus a manual assessment will follow the 2 automated scans.

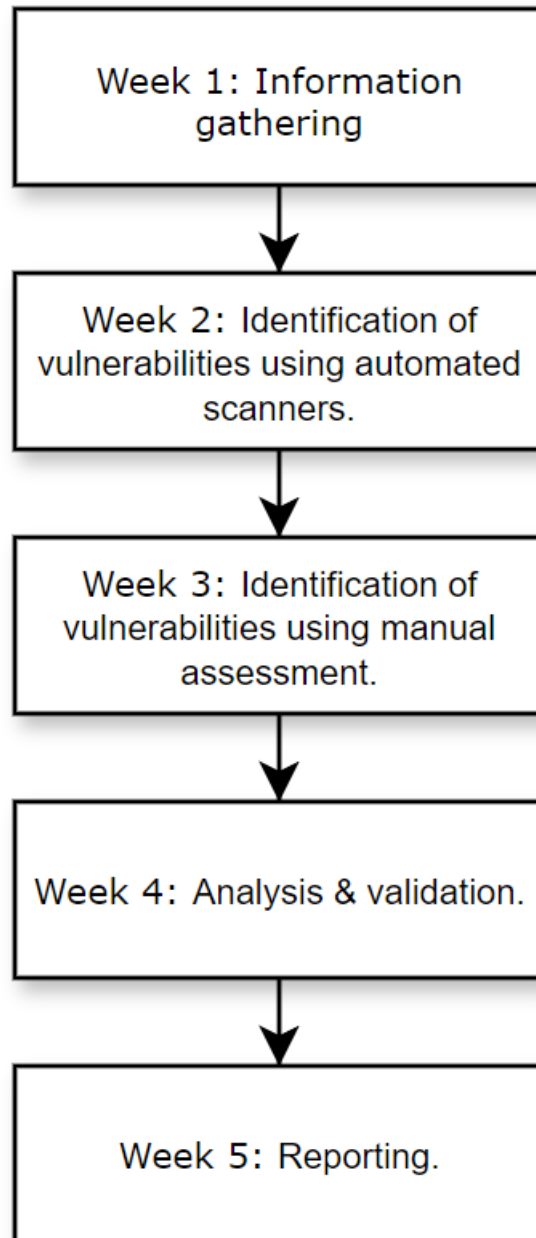
The task of assessing the chosen website for vulnerabilities will be based on Haeruddin et al.'s (2024) vulnerability assessment methodology:

- Information gathering, including an audit of: spiderfoot
 - Human assets;
 - Web assets;
 - Physical assets.
- Identification of vulnerabilities: using OWASP ZAP & Wapiti3 to scan for vulnerabilities, followed up with manual vulnerability discovery to account for false positives and false negatives; //
- Analysis & validation: common vulnerability enumeration will be analysed with comparisons made between the 3 assessments in order to gain a comprehensive validation of results; /make sure to enumerate
- Reporting: a discussion of the validated vulnerabilities and a recommendation of solutions.

Potential business impacts of methodology

A pilot, out-of-hours scan will be conducted in order to test for potential slow-downs on normal user response times as this could affect the business operations of the website (University of Essex Online, N.D). If slow-down is not considerable, an in-hours scan will be conducted to gain insight into the effect of other systems that may be running on the same platform (University of Essex Online, N.D). The scans will be conducted remotely due to the assessors not having access to the company systems.

Vulnerability Assessment Timeline



Summary of limitations

The depth of this vulnerability assessment is limited by a number of factors: an individual is performing the assessment as opposed to a security team with in-depth knowledge of the systems being used; time restrictions have limited the number of scans to be conducted, as well as the detail with which the results can be analysed

and validated; and financial restrictions have limited the choice of automated scanning tools which somewhat limits the validity of its findings.

References

Albahar, M., Alansari, D. and Jurcut, A. (2022) An Empirical Comparison of Pen-Testing Tools for Detecting Web App Vulnerabilities. *Electronics*, 11(19): 1-25. DOI: 10.3390/electronics11192991

Armando, R., Melyantara, I. G. A. K. A., Elfariani, R., Latuconsina, D. F. A., & Nasrullah, M. (2022) IT Support Website Security Evaluation Using Vulnerability Assessment Tools. *Journal of Information Systems and Informatics (Palembang.Online)* 4(4): 949–957. DOI: <https://doi.org/10.51519/journalisi.v4i4.330>

Armando, Y., & Rosalina, R. (2023) Penetration Testing Tangerang City Web Application With Implementing OWASP Top 10 Web Security Risks Framework. *JISA (Jurnal Informatika Dan Sains)* 6(2): 105–109. DOI: <https://doi.org/10.31326/jisa.v6i2.1656>

Dalziel, H. (2015). *How to attack and defend your website*. 1st ed. Waltham, Massachusetts: Syngress. Available from: https://learning.oreilly.com/library/view/how-to-attack/9780128027325/?sso_link=yes&sso_link_from=university-of-essex [Accessed 02 February 2025].

Dharmavaram, V. G. (2021) Formjacking attack: Are we safe? *Journal of Financial Crime* 28(2): 607-6121. DOI: 10.1108/JFC-07-2020-0138

Freeman, A. (2024) *Mastering Node.js Web Development: Go on a Comprehensive Journey from the Fundamentals to Advanced Web Development with Node.js*. First ed. Birmingham: Packt Publishing. Available from: https://learning.oreilly.com/library/view/mastering-node-js-web/9781804615072/?sso_link=yes&sso_link_from=university-of-essex [Accessed 05 February 2025].

GDPR Advisor. (2023) GDPR Compliance Checklist for E-commerce Websites: Ensuring Data Protection in Online Transactions. Available from: <https://www.gdpr-advisor.com/gdpr-compliance-checklist-for-e-commerce-websites-ensuring-data-protection-in-online-transactions/?form=MG0AV3> [Accessed 12 February 2025].

Haeruddin, Gautama Wijaya, Winata, H., Sukma Aji, & Muhammad Nur Faiz. (2024) Website Security Analysis Using Vulnerability Assessment Method: Case Study: Universitas Internasional Batam. *Journal of Innovation Information Technology and Application* 6(2): 173–180. DOI: <https://doi.org/10.35970/jinita.v6i2.2476>

IT Governance. (2025) PCI DSS: Payment Card Industry Data Security Standard. Available from: <https://www.itgovernance.co.uk/pci-dss> [Accessed 15 February 2025].

Kluban, M., Mannan, M., and Youssef, A. (2024) On Detecting and Measuring Exploitable JavaScript Functions in Real-world Applications. *ACM Transactions on Privacy and Security*, 27(1): 1-37. DOI: <https://doi.org/10.1145/3630253>

Landoll, D. (2021). The Security Risk Assessment Handbook
A Complete Guide for Performing Security Risk Assessments. 3rd Ed. Oxon: CRC Press. Available from: https://learning.oreilly.com/library/view/the-security-risk/9781000413250/?sso_link=yes&sso_link_from=university-of-essex [Accessed 08 February 2025].

OWASP. (2021) OWASP Top Ten. Available from: <https://owasp.org/www-project-top-ten/> [Accessed 01 February 2025].

PortSwigger (2023). Gin & Juice Shop. Available from: <https://ginandjuice.shop/> [Accessed 25 January 2025].

Shahid, R., Khan Marwat, S.N., Al-Fuqaha, A. and Ben Brahim, G. (2022) 'A Study of XXE Attacks Prevention Using XML Parser Configuration', *IEEE 11th International Conference on Communication Systems and Network Technologies*. Al-Khobar, Saudi Arabia, 04-06 December. New York: IEEE. 825-831.

Singh, G.D. (2022) *The Ultimate Kali Linux Book*. 2nd Ed. Birmingham: Pact Publishing. Available from: https://learning.oreilly.com/library/view/the-ultimate-kali/9781801818933/?sso_link=yes&sso_link_from=university-of-essex [Accessed 08 February 2025].

University of Essex Online (N.D) *MSc Computer Science Vulnerability Assessments*. [Lecturecast]. NS_PCOM7E Network Security January 2025.. University of Essex Online.

Wu, Z., Shen, S., Zhou, H., Li, H., Lu, C., & Zou, D. (2021) An effective approach for the protection of user commodity viewing privacy in e-commerce website. *Knowledge-Based Systems* 220: 1-12. DOI: <https://doi.org/10.1016/j.knosys.2021.106952>

Yu, W., Liu, L., Wang, X., Bagdasar, O. and Panneerselvam, J. Modeling and Analyzing Logic Vulnerabilities of E-Commerce Systems at the Design Phase. *IEEE Transactions on Systems, Man, and Cybernetics: Systems* 53(12): 7719-7731. DOI: 10.1109/TSMC.2023.3299605